Arquitectura del laboratorio Wazuh (Proyecto final). Despliegue distribuido en VirtualBox

Nov 04, 2026

1. Resumen

El laboratorio se construye **distribuido**: cada integrante arma su VM o VMs en su propia laptop con VirtualBox, sin un equipo central que lo aloje todo. Es la referencia que describe cómo debe quedar la arquitectura para que, al conectar las piezas, funcione como una sola red.

- **Antes de integrar:** cada quien puede probar su VM de forma aislada o en pareja con otro integrante.
- **Integración conjunta:** Cuando las VMs se unen a la red ZeroTier y se ven entre sí con las IP de este documento, sin importar la red física de cada laptop.

2. Inventario de VMs

VM	SO	Rol	IP	RAM / vCPU	Responsable / laptop
wazuh-server	Ubuntu 22.04 LTS	Wazuh Manager + Indexer + Dashboard	192.168.100.10	4 GB / 4	*Kendall*
agent-windows	Windows Server 2022	Active Directory + carpeta compartida (SMB)	192.168.100.30	4 GB / 2	*Juan*
agent-linux	Ubuntu 22.04 LTS Server	Apache + PHP (app web)	192.168.100.20	1.5 GB / 1	Joselyn
agent-db	Debian 13	PostgreSQL + SSH	192.168.100.40	1 GB / 1	Marconi
attacker	Kali Linux 2024	Simulación de ataques controlados	192.168.100.50 (asignación automática, ver nota en sección 5)	2 GB / 2	Angelo
misp	Linux	Servidor MISP (Threat Intelligence)	192.168.100.11	4 GB	Kendall

Todas corren en VirtualBox. Las tres VMs de servicios (agent-linux, agent-windows, agent-db) llevan instalado el agente Wazuh, apuntando por nombre a `wazuh-server`, para no depender de que esa IP exista literalmente en la red de cada quien. attacker no lleva agente: no es un activo a proteger, y lo que se vigila es el rastro que sus ataques dejan en las víctimas.

3. Monitoreo

Todo el monitoreo vive en wazuh-server [1]. Su trabajo es vigilar los cuatro agentes activos: agent-linux, agent-windows, agent-db y misp-agent-linux.

Componente	Qué hace	Puerto
Manager	Recibe eventos de los 4 agentes, los compara contra las reglas y decide el nivel de alerta	1514 (eventos), 1515 (registro de agentes)
Indexer	Guarda las alertas para poder buscarlas después	9200 (interno)
Dashboard	Panel web donde se ven agentes, alertas, SCA y las capturas de cada fase	443
API de gestión	Usada por el dashboard y por integraciones	55000 (interno)

Qué vigila:

- SSH (fallos y root) en agent-linux y agent-db.
- FIM sobre `/etc/passwd`, `/etc/sudoers`, `/var/www` y `C:\Windows\System32`.
- Logs de Apache y PostgreSQL, con decodificadores propios.
- Eventos de Windows: inicio de sesión (4624/4625) y creación de cuentas (4720).
- SCA (configuración) y vulnerabilidades conocidas en el software instalado.

Respuesta e integraciones:

- **Active Response:** cuando se dispara la regla de fuerza bruta SSH (nivel 10+), el manager ordena a agent-db bloquear la IP del atacante con firewall-drop durante 600 segundos [4].
- **VirusTotal:** consulta hashes de archivos detectados por FIM contra su base de datos.
- **Alertas:** nivel 10 o más se notifica por Slack.
- **MISP [6]: enriquecimiento de IoCs, consulta la IP de origen** (o el hash de FIM) contra la base de datos de MISP; si hay coincidencia, genera una alerta (regla 100050).

ID	Nivel	Condición	MITRE	Acción
100001	10	Más de 5 fallos SSH en 60s desde la misma IP	T1110.001	Alerta + bloqueo automático (firewall-drop, 600 s)
100002	12	FIM en /etc/passwd, /etc/sudoers o /etc/sudoers.d	T1098 / T1548.003	Alerta en el dashboard
100003	10	Usuario sin privilegios intenta sudo	T1548.003	Alerta en el dashboard

100005	12	Cuenta de Windows creada fuera de horario laboral	T1136.001 / .002	Alerta en el dashboard
100014	13	Conexión saliente al puerto 4444	T1571	Alerta en el dashboard
100050	12	IP u hash coincide con un IoC de MISP	—	Alerta de enriquecimiento. Marca la IP o el hash como IoC conocido

La clave de VirusTotal y el webhook de Slack no se suben a Git.

4. Backend: agent-linux y agent-db

Son los dos servicios de la empresa ficticia que los ataques de la Fase 5 van a golpear: la app web y la base de datos detrás de ella.

agent-linux (192.168.100.20) — servidor web:

- Apache + PHP, con `mod_status` activo.
- Archivos en `/var/www/html/`: `index.html` (la página), `db_config.php` (conexión a la base de datos) y `consultas.php` (procesa las consultas a la base). La inyección SQL de la Fase 5 apunta a `consultas.php`.
- Logs: `sudo tail -n 15 /var/log/apache2/access.log` y `.../error.log`.
- Escalada de privilegios (T1548.003) [2], aplicable a agent-db y agent-windows: se demuestra en dos frentes. En agent-db, con comprobaciones nativas de Linux (sudo -l, binarios SUID) sobre una regla de sudo mal configurada. En agent-windows, como ataque interno (insider) ejecutado directamente en la máquina — por SSH si hay acceso remoto, o localmente si no — usando los módulos de Atomic Red Team para T1068 en Windows.

agent-db (192.168.100.40) — base de datos:

- PostgreSQL + SSH.
- Para el ataque de fuerza bruta SSH (Fase 5), agent-db tiene una cuenta de prueba de bajo privilegio con contraseña débil, separada de la cuenta administrativa.
- Solo acepta conexiones a PostgreSQL desde 192.168.100.20 (agent-linux), nunca desde el atacante directamente.
- Registra conexiones y errores en su log; ese registro es lo que decodifica y vigila Wazuh.

Dependencia entre ambas: agent-linux necesita de agent-db la IP, el nombre de la base, el puerto, un usuario de solo lectura con su contraseña, que PostgreSQL acepte conexiones desde 192.168.100.20, y el nombre de la tabla y columnas consultables.

5. Red física distribuida

Con las VMs repartidas en 5 laptops distintas, las redes NAT y host-only de VirtualBox no sirven para que se vean entre sí: ambas aíslan la VM dentro de su propia laptop. La arquitectura usa ZeroTier [3], una red virtual (VPN overlay) que conecta las VMs por internet sin depender de que todas estén en la misma red física, evitando coordinar un hotspot o adaptador puente compartido entre las 5 laptops.

Cómo se une cada VM:

1. Dentro de cada VM, con su adaptador NAT normal de VirtualBox [5], ejecutar:

```
curl -s https://install.zerotier.com | sudo bash
sudo zerotier-cli join <código de invitación>
```

2. Quien administra la red del equipo autoriza el dispositivo en my.zerotier.com → pestaña Members. Sin este paso la VM queda unida pero sin IP.

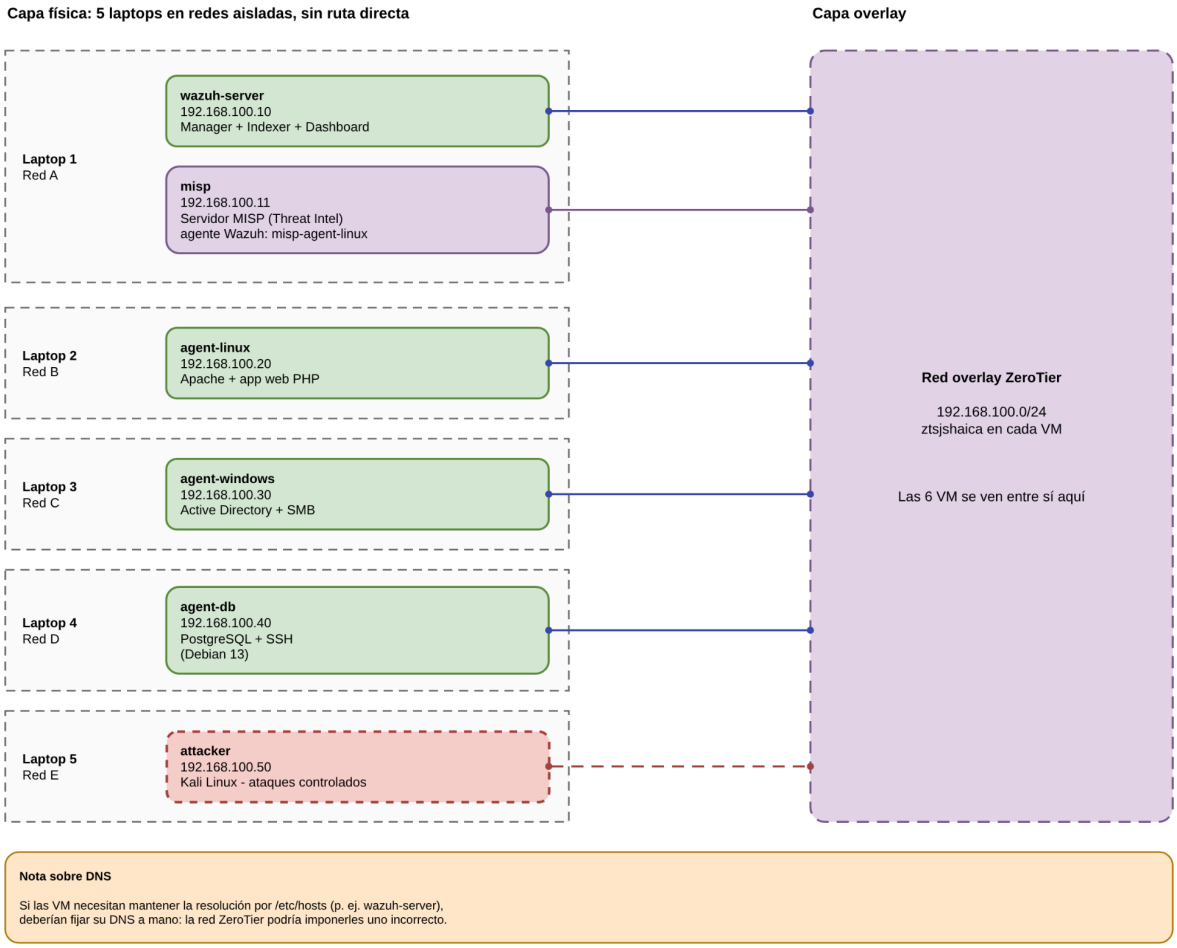
3. ZeroTier crea una interfaz virtual (nombre tipo zt<id>, por ejemplo ztsjshaica en wazuh-server; varía por VM, se confirma con zerotier-cli listnetworks) dentro de la VM, visible desde cualquier otra VM unida a la misma red, sin importar laptop ni red física.

Direccionamiento IP: el rango de la red se fija en my.zerotier.com → Network → IPv4 Auto-Assign como 192.168.100.0/24, con cada VM fijada manualmente en Members según su rol (.10 servidor, .20 web, .30 Windows, .40 base de datos, .50 atacante. Una VM que se une antes de que se le fije su IP manual recibe una del pool automático, que se corrige luego en Members.

DNS: el router de la red ZeroTier puede publicar un servidor DNS a los miembros vía NetworkManager. Como ese valor no es un resolutor real, cada VM fija su DNS manualmente en vez de aceptar el que la red virtual intenta publicar. Las VMs Linux usan resolutores públicos (1.1.1.1, 8.8.8.8) para que apt y la resolución por /etc/hosts sigan funcionando; agent-windows, al ser también servidor DNS del dominio, apunta a sí mismo (192.168.100.30), como exige Active Directory [7].

wazuh-server se referencia por el nombre wazuh-server en /etc/hosts (o el hosts de Windows) de cada VM, apuntando a su IP de ZeroTier. Así no hay que tocar nada si alguna IP cambia. Ventaja sobre un hotspot: esta red funciona todo el tiempo, no solo cuando las 5 laptops están juntas, lo que permite hacer pruebas parciales durante la semana.

Puertos y protocolo: ZeroTier necesita salida a internet por UDP 9993 (atraviesa NAT sin abrir nada en el router). Sobre esa interfaz ZeroTier siguen aplicando los mismos puertos de siempre: 1514 y 1515 hacia wazuh-server (agentes), 443 hacia wazuh-server (dashboard), 80 desde attacker hacia agent-linux, 22 desde attacker hacia agent-db, 5432 desde agent-linux hacia agent-db.



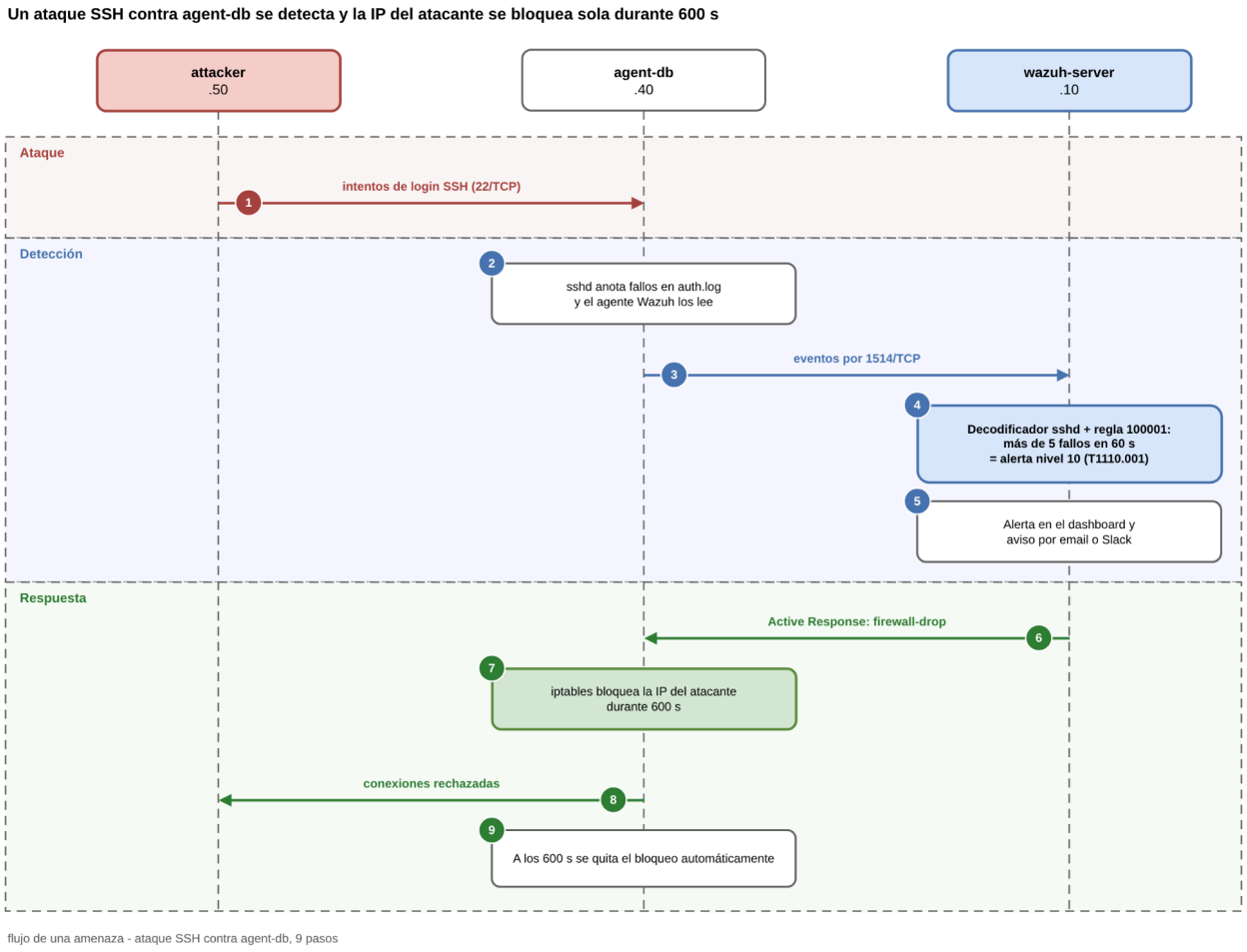
Puertos y protocolo: ZeroTier necesita salida a internet por UDP 9993 (atraviesa NAT sin abrir nada en el router).
Sobre esa interfaz ZeroTier aplican los puertos de cada servicio: 1514 y 1515 hacia wazuh-server (agentes), 443 hacia wazuh-server (dashboard), 80 desde attacker hacia agent-linux (web/SQLi), 22 desde attacker hacia agent-db (SSH/fuerza bruta), 5432 desde agent-linux hacia agent-db, 443 saliente desde wazuh-server hacia misp.

6. Red lógica: zonas y flujos

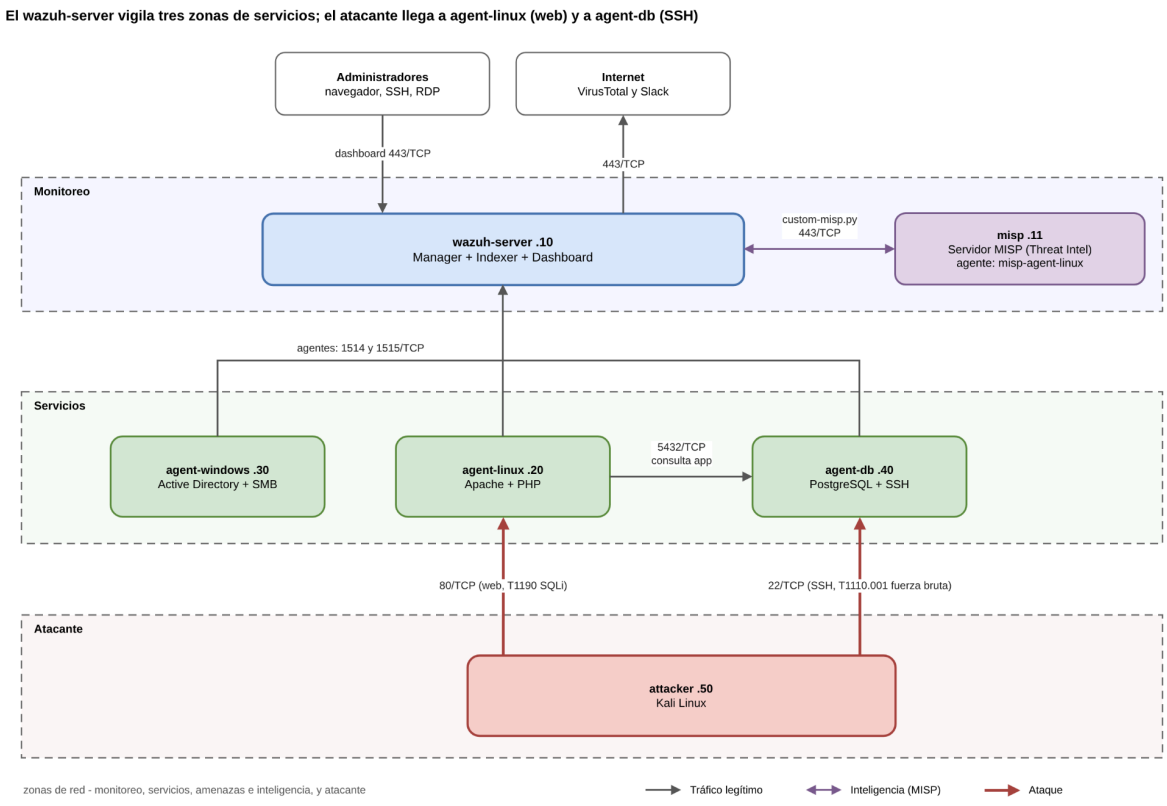
Por encima de la red física (sección 5) hay tres zonas lógicas.

Zona	VMs	Política de acceso
Monitoreo	wazuh-server	Recibe de los agentes por 1514/1515; el dashboard (443) solo lo abren los administradores
Servicios	agent-linux, agent-windows, agent-db	agent-db solo acepta PostgreSQL (5432) desde agent-linux; SSH abierto a administradores y, deliberadamente, al atacante (puerto 22) para la demostración de fuerza bruta de Fase 5
Atacante	attacker	Llega a agent-linux (80) y a agent-db (22) para las pruebas

Esta separación se aplica con el firewall de cada VM (ufw, iptables o Firewall de Windows): todas las VMs comparten la misma red overlay de ZeroTier — es el firewall, no la red, el que decide qué entra.



flujo de una amenaza - ataque SSH contra agent-db, 9 pasos



El atacante genera fallos de SSH contra agent-db; el agente de agent-db los envía al wazuh-server; la regla dispara una alerta nivel 10 (T1110.001) y ordena a agent-db bloquear la IP del atacante por 600 segundos.

7. Referencias

- [1] Wazuh Inc., "Quickstart," Wazuh Documentation 4.14. [Online]. Available: https://documentation.wazuh.com/4.14/quickstart.html. [Accessed: 04-Nov-2026].
- [2] MITRE, "ATT&CK Enterprise Matrix." [Online]. Available: https://attack.mitre.org/. [Accessed: 04-Nov-2026].
- [3] ZeroTier, Inc., "Create a Network," ZeroTier Documentation. [Online]. Available: https://docs.zerotier.com/start/. [Accessed: 04-Nov-2026].
- [4] Wazuh Inc., "Active Response," Wazuh Documentation. [Online]. Available: https://documentation.wazuh.com/current/user-manual/capabilities/active-response/index.html. [Accessed: 04-Nov-2026].
- [5] Oracle, "Chapter 6. Virtual Networking," Oracle VM VirtualBox User Manual. [Online]. Available: https://www.virtualbox.org/manual/ch06.html#network_nat. [Accessed: 04-Nov-2026].
- [6] MISP Project, "MISP Open Source Threat Intelligence Platform." [Online]. Available: https://www.misp-project.org/. [Accessed: 04-Nov-2026].

- [7] Microsoft, "Recommendations for Domain Name System (DNS) client settings," Microsoft Learn. [Online]. Available: https://learn.microsoft.com/en-us/troubleshoot/windows-server/networking/best-practices-for-dns-client-settings. [Accessed: 04-Nov-2026].